



Факултет по Математика и Информатика
ПУ "Паисий Хилендарски"

ВЪВЕДЕНИЕ В ИНТЕРНЕТ СИГУРНОСТТА

Витали Атиас

Какво представлява интернет сигурността

Какво представява интернет сигурността

*Интернет сигурността представлява
съвкупност от принципи, технологии и
практики за защита на системи и данни,
достъпни през интернет.*

Защитава:

- уеб приложения
- комуникация клиент ↔ сървър
- данни и идентичности
- бизнес логика

Какво представява интернет сигурността

Защо е критична?

- Всички системи са свързани към интернет
- Атаките са автоматизирани
- Данните имат икономическа стойност

Какво може да се обърка?

Login форма:

```
POST /login  
username=student1&password=mypassword
```

Моделът CIA Triad

Трите фундаментални свойства

- Конфиденциалност (Confidentiality)
- Цялостност (Integrity)
- Наличност (Availability)

**Система е сигурна само, ако гарантира и
трите!**

CIA Triad

(формален модел)



Конфиденциалност (Confidentiality)

Гарантираче чувствителната информация е достъпна само за оторизирани потребители. Мерките включват криптиране, двуфакторна автентикация (2FA) и управление на достъпа.

Механизми

- TLS
- Encryption
- Access control
- Password hashing

Какво не е наред?

```
app.post("/login", (req, res) => {  
  console.log(req.body.password);  
});
```

Цялостност (Integrity)

Осигурява точността, надеждността и непроменимостта на данните през целия им жизнен цикъл. Включва мерки като цифрови подписи, контрол на версиите и хеширане.

Механизми

- Server-side validation
- Digital signatures
- Hash verification

Пример атака

```
POST /transfer  
amount=100
```

Атакуващ променя

```
amount=10000
```

Има ли решение?

Наличност (Availability)

Гарантираче информацията и системите са достъпни за потребителите когато им потребват. Включва поддържане на хардуерсофтуерни ъпдейти и планове за възстановяване при бедствия.

Типични атаки

- DoS
- Resource exhaustion
- Infinite loops

Какво ще стане със сървъра?

```
while(true) {  
  fetch("http://localhost:3000/login");  
}
```

Какво защитаваме?

Какво защитаваме? (Assets)

Основни активи

- Потребителски акаунти
- Session ID
- JWT
- База данни
- Бизнес логика

Пример

```
Set-Cookie: SESSIONID=abc123
```

Видове атакуващи според профила и мотивацията

- **Киберпрестъпници (Cybercriminals)** - най-разпространената група. Мотивирани са основно от пари (чрез Ransomware, фишинг или продажба на данни).
- **Хактивисти (Hacktivists)** - хакери, движени от идеологически, политически или социални каузи. Техните атаки често целят публично zlepоставяне на цели или промяна на уебсайтове.

Видове атакуващи според профила и мотивацията

- **Държавно спонсорирани (State-Sponsored)** - силно финансирани групи които работят за правителства. Целите им са шпионаж, кражба на интелектуална собственост или дестабилизация на критична инфраструктура.
- **Вътрешни заплахи (Insider Threats)** - настоящи или бивши служители, които злоупотребяват с достъпа си. Те могат да действат умишлено (отмъщение, печалба) или неволно (поради небрежност).

Видове атакуващи и методи на атака

Неавтентикиран (Външен атакуващ) - Лице без легитимен достъп до системата, което се опитва да пробие периметъра.

- **SQL Injection** - вмъкване на зловреден код в заявки към базата данни за извличане на информация.
- **Brute Force** - автоматизирани опити за отгатване на пароли чрез изпробване на всички възможни комбинации.

Видове атакуващи и методи на атака

Автентикиран (Вътрешен/Компрометиран потребител) - лице, което вече притежава валидни данни за достъп, но злоупотребява с тях.

- **Horizontal Privilege Escalation** -

атакуващият успява да получи достъп до данни или функции на друг потребител със същото ниво на привилегии (напр. потребител А достъпва профила на потребител Б).

Видове атакуващи и методи на атака

Автоматизиран (Машинен атакуващ) - атаки, извършвани от софтуерни скриптове без директна човешка намеса в реално време.

- **Bots** - програми, изпълняващи повтарящи се задачи с цел сканиране на уязвимости или претоварване на системи.
- **Credential Stuffing** - вид автоматизирана атака, при която ботове използват списъци с откраднати потребителски имена и пароли от една услуга, за да влязат неправомерно в други платформи.

Вектори на атака (Attack Vectors)

Когато говорим за вектори на атака през погледа на софтуерната разработка, ние се фокусираме върху уязвимостите в кода, архитектурата и жизнения цикъл на разработка (SDLC).

Вектори на атака (Attack Vectors)

Вектори на ниво код (Implementation Level)

- **Injection** - приемане на потребителски вход, който се интерпретира като част от команда или заявка (SQL, NoSQL, OS Command).
- **Insecure Deserialization (Несигурна десериализация)** - Възстановяване на обекти от данни с ненадежден произход, водещо до отдалечено изпълнение на код (RCE).
- **Hardcoded Secrets** - вграждане на пароли, API ключове или сертификати директно в сорс кода или конфигурационните файлове.
- **Sensitive Data Exposure** - използване на слаби криптографски алгоритми или липса на шифроване при пренос и съхранение на данни.

Вектори на атака (Attack Vectors)

Вектори на ниво архитектура и логика (Design Level)

- **Zero-Day Vulnerability** - неизвестен за разработчика дефект в логиката или защитата, който се експлоатира преди наличието на официална корекция.
- **Broken Access Control** - неправилно имплементирани ограничения, позволяващи на потребители да достъпват ресурси извън техните привилегии (напр. IDOR).
- **Business Logic Errors** - пропуски в дизайна на бизнес процесите, позволяващи манипулация на функционалности (напр. заобикаляне на стъпки за плащане).
- **Broken Authentication** - слабости в механизмите за управление на сесии и идентификация (напр. предвидими сесийни токени).

Вектори на атака (Attack Vectors)

Вектори на ниво жизнен цикъл и среда (Supply Chain & SDLC)

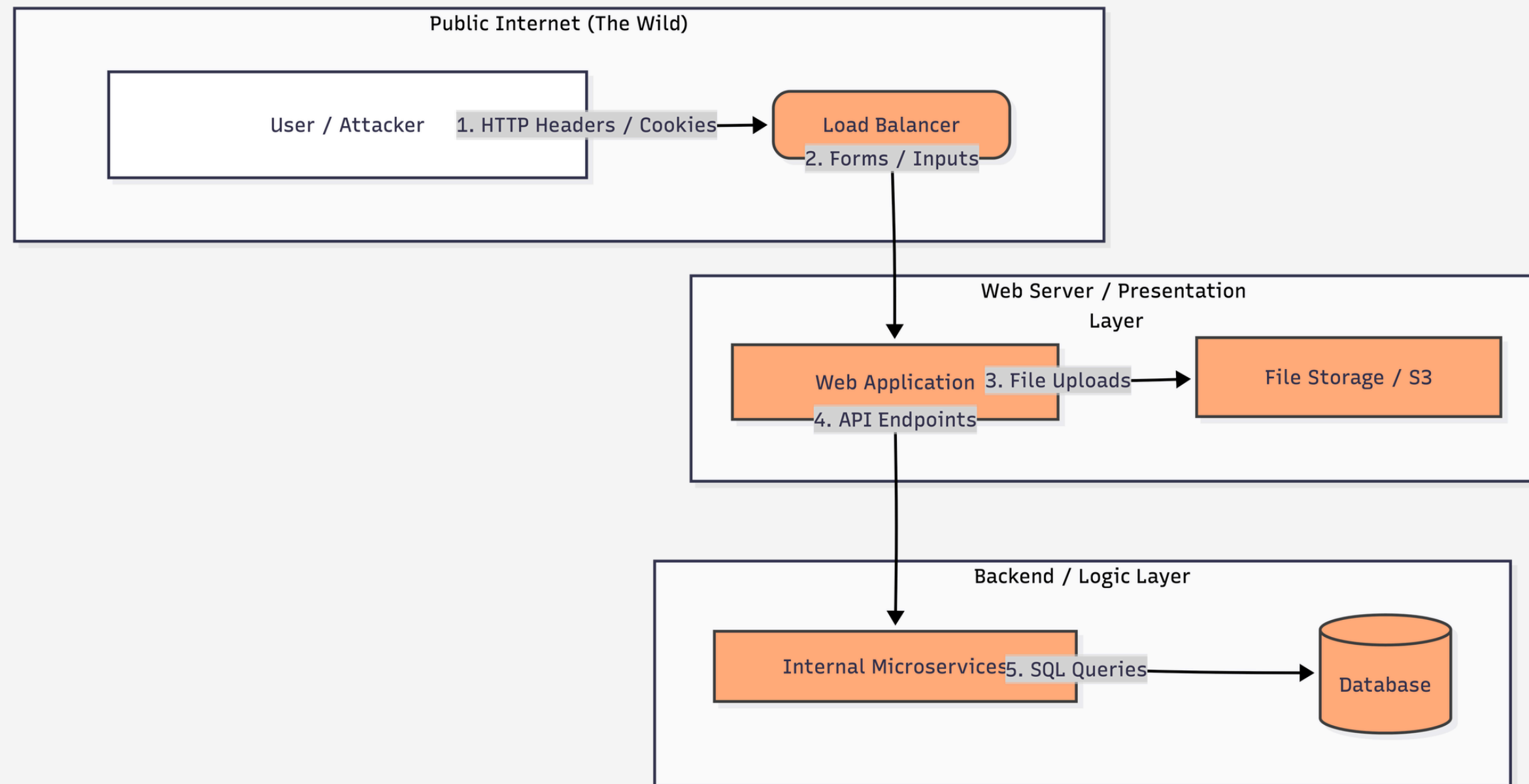
- **Vulnerable Dependencies** - използване на библиотеки от трети страни с известни уязвимости или остаряла поддръжка.
- **Supply Chain Attack** - компрометиране на процеса по изграждане (build) или вмъкване на злонамерен код в публични хранилища за пакети (npm, PyPI).
- **Security Misconfiguration** - неправилна настройка на сървъри, облачни услуги или активирани дебъг режими в продукционна среда.
- **Insufficient Logging & Monitoring** - липса на проследимост на събитията, което възпрепятства откриването и реакцията при активен пробив.

Повърхност за атака (Attack Surface)

Сборът от всички точки за достъп, през които неоторизиран потребител (атакуващ) може да се опита да въведе данни в системата или да извлече информация от нея. Колкото по-голяма е повърхността, толкова по-висок е рискът.

Основни разлики - докато **Векторът** е „как“ се извършва атаката (методът), **Повърхността** е „къде“ може да бъде атакувана системата.

Повърхност за атака (Attack Surface)



Повърхност за атака (Attack Surface)

Софтуерна повърхност

- **User Interface (UI) входове** - всички полета за данни, форми, качване на файлове и интерфейси, чрез които потребителят взаимодейства директно с кода.
- **API Ендпоинти** - публични и частни интерфейси (REST, GraphQL, gRPC), които излагат функционалности на приложението към външни системи.
- **Services & Microservices** - всички активни фонове процеси, опашки от съобщения (RabbitMQ, Kafka) и микроуслуги, които комуникират в рамките на системата.
- **Database Layer** - Връзките и заявките към базите данни, както и съхранените процедури, които могат да бъдат манипулирани.

Повърхност за атака (Attack Surface)

Мрежова повърхност

- **Отворени портове и протоколи** - всички слушащи портове (HTTP/S, SSH, FTP) и комуникационни канали, които са достъпни от външни или вътрешни мрежи.
- **Network Interfaces** - точките на свързване между различни сегменти на мрежата.
- **Cloud Infrastructure** - неправилно конфигурирани облачни ресурси (S3 buckets, публични IP адреси, виртуални мрежи), които излагат приложението на риск.

Повърхност за атака (Attack Surface)

Повърхност на зависимостите

- **Библиотеки от трети страни** - целият сорс код, импортиран чрез пакетни мениджъри (пример npm), който става част от изпълнимата среда.
- **Container Images** - базови изображения (Docker images), съдържащи предварително инсталиран софтуер, върху който работи приложението.
- **CI/CD Пайплайни** - Скриптове за автоматизация, инструменти за компилиране и системи за разгръщане, които могат да бъдат компрометирани за вмъкване на злонамерен код.

Повърхност за атака (Attack Surface)

Човешка и административна повърхност

- **Administrative Interfaces** - панели за управление и инструменти за конфигурация, които изискват високи нива на достъп.
- **Secrets Management** - начинът на съхранение и достъп до ключове, сертификати и пароли от страна на разработчиците и DevOps екипите.
- **Достъп на разработчици** - Правата за достъп до сорс кода (Git хранилища) и възможността за промяна на производствената среда.

STRIDE model

Моделът STRIDE е методология за класификация на заплахите, разработена от Microsoft, която помага на разработчиците да идентифицират какво може да се обърка в една система.

Категории

- Spoofing
- Tampering
- Repudiation
- Information Disclosure
- Denial of Service
- Elevation of Privilege

STRIDE model

- **Spoofing (Самоличност)** - атакуващият се представя за друг легитимен потребител, компонент или система.
- **Tampering (Подправяне)** - неоторизирана модификация на данни при тяхното съхранение (в база данни) или по време на техния обмен (през мрежата).
- **Repudiation (Отричане)** - възможността на потребител да отрече извършването на дадено действие или трансакция поради липса на доказателства (логове) за неговата активност.

STRIDE model

- **Information Disclosure (Разкриване на информация)** - Неразрешен достъп до чувствителна информация от субекти, които нямат право да я виждат (изтичане на данни, логове или метаданни).
- **Denial of Service (Отказ от услуга)** - изчерпване на ресурсите на системата (CPU, памет, мрежов трафик), което я прави недостъпна за легитимни потребители.
- **Elevation of Privilege (Ескалация на привилегии)** - Потребител с ограничени права придобива по-високи нива на достъп (администраторски), което му позволява да компрометира цялата система.

STRIDE model

Категория	Заплаха (Threat)	Дефиниция / Сценарий
Spoofing	Credential Stuffing	Атакуващият използва автоматизирани скриптове с откраднати потребителски имена и пароли от други сайтове, за да се впише неправомерно.
Tampering	Параметрично манипулиране	Промяна на HTTP POST параметрите (напр. скрити полета като is_admin=false на true) преди изпращане към сървъра.
Repudiation	Липса на одит	Потребител извършва злонамерени действия, но системата не записва кой и кога се е логнал, което позволява на нарушителя да отрече действията си.
Information Disclosure	Username Enumeration	Формата връща различни съобщения за грешка („Грешна парола“ срещу „Потребителят не съществува“), разкривайки кои имейли са регистрирани.
Denial of Service	Account Lockout DoS	Умишлено блокиране на легитимни акаунти чрез многократно въвеждане на грешни пароли, докато системата не ги деактивира автоматично.
Elevation of Privilege	Session Hijacking	След успешен вход, атакуващият открадва сесийната бисквитка (Cookie) и придобива правата на потребителя без нужда от парола.